



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:



Aplicación práctica y análisis de casos

Módulo 11



Casos reales: WannaCry en hospitales

¿Qué fue WannaCry?

WannaCry fue un ataque masivo de ransomware que explotó una vulnerabilidad crítica en sistemas Windows (conocida como **EternalBlue**, filtrada desde la NSA). Se propagaba como gusano y cifraba los archivos del sistema, exigiendo un rescate en bitcoin.

Fecha: 12 de mayo de 2017

Objetivo: indiscriminado, pero afectó gravemente a sistemas críticos en todo el mundo, incluyendo **hospitales, fábricas, transporte y telecomunicaciones**.

Impacto en hospitales (caso NHS – Reino Unido)

¿Qué tipo de sistemas fueron afectados?

- Sistemas de gestión de pacientes (IT)
- Equipos conectados a red (OT): **máquinas de rayos X, resonancias, bombas de infusión, ecógrafos, ordenadores médicos de quirófano**
- Sistemas de laboratorio y diagnóstico automatizado
- Servidores que controlaban sistemas logísticos y citas médicas

Aunque WannaCry no estaba diseñado específicamente para OT, **el hecho de que muchos equipos médicos operaban con Windows sin parches y estuvieran conectados a red los hizo vulnerables**.

Casos reales: WannaCry en hospitales

Impacto general

A nivel humano (personas)

- Se cancelaron más de **19.000 citas médicas**, muchas de ellas operaciones urgentes.
- Ambulatorios y centros de salud quedaron **desconectados**.
- Las ambulancias fueron redirigidas porque no se podían recibir nuevos pacientes.
- **Pacientes oncológicos, quirúrgicos y crónicos** vieron interrumpidos sus tratamientos.

Impacto financiero

- El **informe oficial del gobierno británico** estimó un coste total de más de **92 millones de libras esterlinas** (~105 millones de euros).
 - 72 millones en coste directo (interrupción, cancelaciones, restauración)
 - 19 millones en coste adicional de limpieza y refuerzo posterior
- Se estima que a nivel global WannaCry causó **más de 4.000 millones USD** en pérdidas.

Casos reales: WannaCry en hospitales

Impacto reputacional

- El NHS fue duramente criticado por no haber actualizado sus sistemas (muchos seguían usando **Windows XP**).
- El ataque expuso la **fragilidad de infraestructuras críticas sanitarias** frente a amenazas cibernéticas.
- La confianza pública en la capacidad del sistema sanitario para proteger datos y garantizar operaciones se vio comprometida.
- Se generaron portadas internacionales sobre la “parálisis hospitalaria por ciberataque”.

Casos reales: WannaCry en hospitales

¿Por qué afectó también al OT hospitalario?

- Muchos equipos médicos (radiología, anestesia, quirófano) **funcionan con sistemas embebidos basados en Windows**.
- No estaban aislados de la red administrativa, lo que facilitó la propagación del malware.
- **No existía una política activa de parcheo ni de segmentación entre redes clínicas y corporativas**.
- La prioridad de disponibilidad en hospitales lleva muchas veces a evitar reinicios y actualizaciones.

Lecciones aprendidas

- **OT en sanidad también es cibercrítico**, aunque históricamente se consideraba fuera del ámbito de TI.
- La segmentación de redes y la gestión de parches son claves para mitigar estos ataques.
- La ciberseguridad OT debe estar incluida en las políticas de continuidad de negocio y gestión de riesgos del sector salud.
- Tras el incidente, el gobierno británico invirtió más de 150 millones de GBP en actualizar y proteger los sistemas del NHS.

Casos reales: Colonial Pipeline

Ciberataque que paralizó la distribución de combustible en EE. UU.

Fecha: Mayo de 2021

Empresa afectada: **Colonial Pipeline Company**, principal operador de oleoductos en EE. UU., responsable de transportar el 45% del combustible de la costa este (gasolina, diésel, queroseno de aviación).

¿Qué ocurrió?

El 7 de mayo de 2021, Colonial Pipeline fue víctima de un **ataque de ransomware** lanzado por el grupo criminal **DarkSide**.

Aunque el malware afectó principalmente a los **sistemas IT**, la empresa **decidió desconectar preventivamente sus sistemas OT (SCADA, control de válvulas, bombeo, sensores)** para evitar que el ataque se propagara.

Resultado: se detuvo toda la operación del oleoducto durante varios días.

Casos reales: Colonial Pipeline

¿Qué sistemas fueron afectados?

IT comprometido directamente:

- Sistemas de facturación y finanzas
- Servidores de correo
- Directorio activo
- Documentos corporativos y credenciales

OT apagado de forma preventiva:

- SCADA y sistemas de control industrial
- Comunicaciones con válvulas y sensores de presión/flujo
- Control de bombeo de estaciones de carga

Casos reales: Colonial Pipeline

Impacto del incidente

A nivel humano y social:

- Escasez de combustible en múltiples estados (Georgia, Florida, Carolina del Norte, etc.)
- Largas colas en gasolineras, pánico social
- Vuelos afectados en algunos aeropuertos regionales
- Pérdida de confianza en la seguridad de infraestructuras energéticas

Impacto financiero:

- Colonial Pipeline pagó **4,4 millones USD** en rescate en criptomonedas (una parte fue luego recuperada por el FBI).
- Estimaciones de pérdidas totales en la economía estadounidense: **varios cientos de millones de dólares**, debido a:
 - Parón logístico
 - Especulación del precio del combustible
 - Costes de recuperación, auditorías, sanciones y mejoras

Casos reales: Colonial Pipeline

Impacto en imagen pública y regulatorio:

- Exposición pública de la debilidad cibernética en infraestructuras críticas OT
- La Casa Blanca emitió un **estado de emergencia nacional**
- Impulso directo al desarrollo de nuevas normativas como la "**Cyber Incident Reporting for Critical Infrastructure Act**" (EE.UU., 2022)
- En Europa reforzó el enfoque de NIS2 hacia entornos OT

Casos reales: Colonial Pipeline

Análisis técnico y operativo

Fallo principal	Descripción
 Robo de credenciales VPN sin MFA	El acceso inicial se logró mediante credenciales filtradas previamente y sin doble autenticación.
 No había separación estricta entre IT/OT	Aunque el malware no cruzó, no existían suficientes barreras o segmentaciones físicas/lógicas.
 Reacción descoordinada	La decisión de apagar OT fue manual, urgente y sin preparación formal.
 Falta de entrenamiento y planes de contingencia	No había simulaciones ni protocolos activos de ciber crisis con el equipo OT.

Lecciones aprendidas

1. Los ataques a IT pueden provocar parálisis en OT incluso sin penetrar físicamente en los sistemas industriales.
2. Es imprescindible establecer segmentación de redes robusta (air gapping, firewalls OT, zonas/zonas IEC 62443).
3. La gestión de accesos remotos debe incluir MFA y monitoreo.
4. Los procedimientos de respuesta a incidentes deben integrarse entre IT y OT.
5. Las autoridades nacionales y sectoriales pueden intervenir si el incidente afecta al interés general.

Casos reales: Hydro Norsk

Ataque de ransomware en una multinacional del aluminio

Fecha: 19 de marzo de 2019

Empresa afectada: Norsk Hydro ASA

Multinacional noruega líder en producción de aluminio con operaciones en más de 40 países y más de 35.000 empleados.

¿Qué ocurrió?

Hydro sufrió un ataque de ransomware **LockerGoga**, un malware que cifró cientos de servidores y estaciones de trabajo en cuestión de horas.

Aunque **inicialmente afectó sistemas IT**, el impacto se extendió rápidamente a las operaciones industriales (OT), obligando a **detener o ralentizar líneas de producción**.

¿Qué es LockerGoga?

- Un ransomware poco común:
- No se propaga por sí solo como WannaCry.
- No siempre cifra todo: en ocasiones **bloquea el acceso sin cifrar archivos**.
- **Desactiva el acceso a red y a sistemas de autenticación**, dificultando la respuesta.

Casos reales: Hydro Norsk

Resumen ejecutivo

Elemento	Detalles
Empresa afectada	Norsk Hydro ASA (Noruega), segunda empresa mundial de aluminio
Ataque	Ransomware <i>LockerGoga</i> desplegado manualmente en sistemas internos (CyberScoop)
Fecha de comienzo	madrugada del 19 de marzo de 2019 (hora CET) (nozominetworks.com , Security Boulevard)
Áreas afectadas	IT global (~3.000 servidores y miles de PCs), impactando varios países (Source , Security Boulevard)
Impacto operativo	Parada o cambio a modo manual en plantas clave (e.g. planta de extrusión) (nozominetworks.com , Security Boulevard)
Coste estimado	~800 millones NOK (~70 millones USD) hasta mayo 2019 (hydro.com , bankinfosecurity.com)
Respuesta	Decisión de no pagar rescate , activación de manual operations, participación de Microsoft DART y transparencia pública (Source , TIME)

Casos reales: Hydro Norsk

Impacto en IT y OT

Área	Impacto
IT	Servidores Windows, AD, correo, ERPs completamente caídos.
OT	Sistemas de control de producción afectados indirectamente. Líneas detenidas o puestas en modo manual.
Comunicaciones	Pérdida de red interna y externa. Se usaron pizarras blancas, móviles y notas escritas.
Administración	Sin acceso a finanzas, facturación, logística ni recursos humanos.

Casos reales: Hydro Norsk

Impacto económico directo

- Pérdidas estimadas: **más de 70 millones de euros** (costes de recuperación, producción perdida, refuerzo de seguridad).

Impacto organizativo

- Operaciones parcialmente paralizadas en **EE. UU., Brasil, Alemania, Noruega y otras plantas europeas.**
- Se recurrió a **operaciones manuales** en plantas industriales para mantener la producción básica.
- El ataque tardó **semanas en contenerse completamente.**

Impacto reputacional

- Hydro fue alabada por su **transparencia ejemplar**: comunicó el incidente desde el primer momento, rechazó pagar el rescate y colaboró con las autoridades.
- Su respuesta fue considerada un **modelo de gestión de crisis.**

Casos reales: Hydro Norsk

¿Qué medidas fallaron?

- **No segmentación estricta de redes IT/OT.**
- **Permisos excesivos y falta de control de accesos** entre dominios.
- **Falta de detección temprana** del ransomware en la red.
- **Sistemas OT con dependencias de IT (SCADA con Windows, integraciones con ERP).**

¿Qué hicieron bien?

- Activaron su **plan de contingencia y continuidad** (aunque tuvo que adaptarse sobre la marcha).
- No pagaron el rescate, optaron por recuperación propia.
- Contaron con **copias de seguridad offline efectivas.**
- Apostaron por la **comunicación transparente con medios, inversores y empleados.**

Casos reales: Hydro Norsk

Lecciones clave para entornos OT

Lección	Relevancia OT
IT y OT están interconectados	El compromiso de IT puede afectar directamente la producción OT.
Planes de continuidad son esenciales	Las plantas pudieron seguir operando en modo manual gracias a la preparación previa.
Transparencia fortalece la resiliencia organizativa	Ganaron prestigio pese a las pérdidas.
La ciberseguridad OT requiere inversión proactiva	La recuperación duró semanas pese a una reacción bien gestionada.

En el contexto de NIS2 y gestión de riesgos OT

- Gestión de incidentes
- Continuidad operativa
- Resiliencia OT
- Gobernanza desde la dirección
- Coordinación con autoridades (CERT, CSIRT, agencias nacionales)